

Checklist

Logging and Monitoring

SIEM (Security Information and Event Management) Planning and Design

- ☐ Define the SIEM's coverage scope.
- ☐ Identify compliance requirements that affect logging.
- ☐ Identify the organization's highest-risk and highest-value systems.
- ☐ Establish security scenarios and use cases the SIEM should detect.
- ☐ Map likely attacks to frameworks such as MITRE ATT&CK or the Cyber Kill Chain.
- ☐ Determine which alerts should be prioritized.
- ☐ Avoid treating every possible event as equally important.
- ☐ Perform proof-of-concept testing before relying on detection rules.
- ☐ Conduct penetration tests or red-team exercises to validate SIEM detections.
- ☐ Create a Record of Authority (ROA) defining log storage locations and retention periods.
- ☐ Ensure logs are stored centrally rather than only on the systems that generate them.
- ☐ Determine whether to collect all available logs or only logs needed for security and operational objectives.
- ☐ Consider storage, indexing, transmission, and licensing costs when defining logging scope.
- ☐ Start with high-value log sources and expand coverage over time.

Log Analysis and Alerting

- ☐ Continuously analyze centralized logs.
- ☐ Configure real-time or near-real-time alerts for important events.
- ☐ Verify that expected events are actually being logged.
- ☐ Tune default operating-system logging settings where necessary.
- ☐ Tune alert rules to reduce false positives.
- ☐ Check for false negatives by testing known suspicious behavior.

- ☐ Correlate events across multiple log sources.
- ☐ Use threat intelligence to enrich and prioritize detections.
- ☐ Keep alerts focused, useful, and actionable.
- ☐ Regularly review and update detection logic as the environment changes.

Windows and Sysmon

- ☐ Deploy Sysmon where enhanced Windows endpoint logging is required.
- ☐ Select and maintain an appropriate Sysmon configuration.
- ☐ Verify Sysmon logs appear under [Applications and Services Logs → Microsoft → Windows → Sysmon](#).
- ☐ Forward Sysmon events to the SIEM.

Important Sysmon Events

- ☐ Monitor **Event ID 1 – Process Creation**.
- ☐ Record executable paths, command lines, users, hashes, parent processes, and signatures.
- ☐ Alert on suspicious parent-child process relationships.
- ☐ Monitor **Event ID 3 – Network Connection Detected**.
- ☐ Correlate outbound connections with the processes that created them.
- ☐ Investigate unusual destination IPs, domains, ports, and protocols.
- ☐ Monitor **Event ID 4 – Sysmon Service State Changed**.
- ☐ Alert when the Sysmon service is unexpectedly stopped or disabled.
- ☐ Monitor **Event ID 13 – Registry Value Set**.
- ☐ Watch persistence-related registry locations such as Windows Run and RunOnce keys.
- ☐ Monitor **Event ID 22 – DNS Query**.
- ☐ Associate DNS requests with originating processes.
- ☐ Investigate suspicious domains, command-and-control infrastructure, and unusual DNS behavior.

Windows Group Policy and Auditing

- ☐ Configure advanced Windows auditing through Group Policy.
- ☐ Enable authentication-related event logging.
- ☐ Confirm security-related Windows Event IDs are being forwarded to the SIEM.
- ☐ Standardize logging settings across domain systems.

- ☐ Review logging policies whenever new Windows systems are deployed.

Authentication Monitoring

- ☐ Alert on repeated failed login attempts above an appropriate threshold.
- ☐ Investigate possible password spraying.
- ☐ Investigate brute-force authentication attempts.
- ☐ Identify abnormal authentication patterns.
- ☐ Monitor privileged-account logins.
- ☐ Detect authentication over insecure clear-text protocols such as HTTP or Telnet.
- ☐ Eliminate insecure authentication methods where possible.

Application Logs

- ☐ Collect logs from internet-facing applications.
- ☐ Monitor excessive HTTP 4XX responses.
- ☐ Investigate repeated access attempts to unusual URLs.
- ☐ Look for URL enumeration and brute-force activity.
- ☐ Monitor repeated connection attempts with little or no valid transaction activity.
- ☐ Detect reconnaissance such as port scanning and service probing.
- ☐ Establish a baseline of normal applications, services, processes, and open ports.
- ☐ Alert on new or unauthorized services, processes, or ports.

Cloud Logging

General

- ☐ Understand the cloud provider's shared-responsibility model.
- ☐ Ensure administrative and API activity is logged.
- ☐ Centralize cloud logs with the rest of the security monitoring environment.
- ☐ Retain cloud logs for an appropriate period.
- ☐ Alert on unexpected configuration and access changes.

AWS

- ☐ Enable and collect AWS CloudTrail logs.
- ☐ Monitor API caller identity, timestamps, and source IP addresses.
- ☐ Collect VPC Flow Logs.

- ☐ Use EventBridge where appropriate to capture and route events.
- ☐ Configure Amazon GuardDuty if threat-detection capabilities are required.
- ☐ Forward relevant AWS security logs into the SIEM.

Microsoft Azure

- ☐ Collect Azure Monitor telemetry.
- ☐ Collect Azure activity logs.
- ☐ Monitor Azure AD/identity sign-in activity.
- ☐ Collect Azure resource logs for relevant services.
- ☐ Configure Microsoft Defender for Cloud where appropriate.
- ☐ Forward Azure security events to the SIEM.

Google Cloud Platform

- ☐ Enable Cloud Logging.
- ☐ Collect audit logs.
- ☐ Configure alerts for relevant GCP events.
- ☐ Use Log Analytics or Log Router where appropriate.
- ☐ Configure Event Threat Detection where required.
- ☐ Forward important GCP logs to the SIEM or other central monitoring platform.

Database Monitoring

- ☐ Log successful and attempted access to sensitive data.
- ☐ Identify users or applications accessing databases they do not normally use.
- ☐ Monitor database queries.
- ☐ Monitor database or table creation, copying, modification, and deletion.
- ☐ Closely monitor activity performed by privileged database users.
- ☐ Alert on activity outside established baselines.
- ☐ Detect possible bulk data exfiltration.
- ☐ Monitor repeated failed authentication attempts.
- ☐ Alert on unexpected privilege escalation.
- ☐ Investigate unusually large query volumes.

DNS Monitoring

- ☐ Log DNS queries and responses.

- ☐ Preserve enough data to associate DNS activity with the correct endpoint.
- ☐ Monitor DNS traffic for malicious domains.
- ☐ Look for command-and-control activity.
- ☐ Detect malware using domain generation algorithms (DGAs).
- ☐ Use endpoint DNS telemetry such as Sysmon where appropriate.
- ☐ Correlate DNS events with process, network, and endpoint logs.

Endpoint Protection

- ☐ Forward EDR/XDR or endpoint protection logs to the SIEM.
- ☐ Monitor malware detections.
- ☐ Monitor suspicious file hashes and signatures.
- ☐ Monitor malicious or unusual endpoint behavior.
- ☐ Ensure endpoint solutions are properly tuned.
- ☐ Verify endpoint detections are included in centralized alerting.

IDS/IPS

- ☐ Forward IDS/IPS events into centralized logging.
- ☐ Review high- and critical-severity alerts.
- ☐ Tune signatures and rules to reduce false positives.
- ☐ Avoid overwhelming analysts with low-value alerts.
- ☐ Retain lower-priority events when they may assist later investigations.

Operating-System Logs

- ☐ Collect Windows endpoint and server logs.
- ☐ Collect Linux/Unix system logs.
- ☐ Establish normal operating-system baselines.
- ☐ Alert on unexpected processes.
- ☐ Monitor command-line activity.
- ☐ Monitor PowerShell activity on Windows.
- ☐ Monitor suspicious shell commands on Linux.
- ☐ Consider tools such as Sysmon, osquery, or OSSEC for additional endpoint visibility.
- ☐ Use file-integrity monitoring where required.

Proxy and Firewall Logs

- ☐ Collect inbound and outbound connection logs.
- ☐ Investigate outbound connections to unexpected services.
- ☐ Monitor connections to unauthorized cloud-storage or messaging platforms.
- ☐ Alert on known command-and-control IP addresses and hostnames.
- ☐ Use blocklists carefully and recognize that they may be incomplete or outdated.
- ☐ Detect connections using unexpected ports or protocols.
- ☐ Look for unusually long-lasting connections.
- ☐ Monitor abnormal bandwidth usage.
- ☐ Investigate low-bandwidth, long-duration connections that may indicate tunneling.

User Accounts, Groups, and Permissions

- ☐ Monitor use of default or shared accounts.
- ☐ Restrict default accounts where possible.
- ☐ Alert when default accounts are used unexpectedly.
- ☐ Monitor changes to privileged Active Directory groups.
- ☐ Alert on additions to Domain Admins, Enterprise Admins, and similar groups.
- ☐ Monitor creation of new local user accounts.
- ☐ Monitor additions to local administrator groups.
- ☐ Investigate unexpected privilege changes.

Detection Testing and Continuous Improvement

- ☐ Test alerts internally on a regular basis.
- ☐ Reproduce expected malicious behaviors in a controlled environment.
- ☐ Confirm that each test generates the expected log data.
- ☐ Confirm that the SIEM generates the expected alert.
- ☐ Automate repeatable tests where practical.
- ☐ Conduct tabletop exercises.
- ☐ Use tabletop exercises to identify missing detections.
- ☐ Perform periodic full logging audits.
- ☐ Check that all expected endpoints are sending logs.
- ☐ Compare current log volume with historical baselines.
- ☐ Investigate unexpected increases or decreases in log volume.
- ☐ Verify that all network ingress and egress points are covered.

- ☐ Check whether newly deployed software should be sending logs to the SIEM.
- ☐ Retest detections after major configuration or infrastructure changes.

Detection Frameworks and Use Cases

- ☐ Map important detections to **MITRE ATT&CK** tactics and techniques.
- ☐ Use ATT&CK to identify gaps in detection coverage.
- ☐ Create threat models based on the organization's most significant risks.
- ☐ Build detection use cases around access control.
- ☐ Build detection use cases around perimeter defense.
- ☐ Build detection use cases around intrusion detection.
- ☐ Build detection use cases around malware.
- ☐ Build detection use cases around application attacks.
- ☐ Build detection use cases around resource integrity.
- ☐ Consider using **Sigma** as a portable detection-rule format.
- ☐ Review community Sigma rules for useful baseline detections.
- ☐ Customize generic Sigma rules for the local environment.
- ☐ Test every imported or newly created rule before relying on it.
- ☐ Map detection rules to relevant ATT&CK techniques when possible.

Ongoing SIEM Maintenance

- ☐ Review SIEM configuration regularly.
- ☐ Update detections when new systems are added.
- ☐ Update detections when new threats are identified.
- ☐ Retune alerts as normal network behavior changes.
- ☐ Remove or modify consistently noisy rules.
- ☐ Review log-retention requirements periodically.
- ☐ Confirm adequate storage capacity.
- ☐ Document changes to logging and detection configurations.
- ☐ Periodically reassess whether logging coverage matches organizational risk.
- ☐ Ensure analysts know how to investigate every alert that is enabled.